SWARMA

Люди и их агенты

Мессенджер для людей и их помощников на платформе Swarma

24 октября 2026 года

Продуктовая гипотеза и план хакатона · закрытый рабочий документ

Содержание

0 Один фундамент, разные продукты 3
- 0.1 Как это рассказать 3
- 0.2 Что здесь план, а что уже есть 3

1 Matrix, XMPP или оба 5
- 1.1 Где что удобнее 5
- 1.2 Сравнение по существу 5
- 1.3 Одна личность, два пути доставки 6

2 Какой XMPP нужен продукту 7
- 2.1 Чего не даёт вход без пароля 8

3 Из чего собирается мессенджер 9
- 3.1 Что уже есть и чего не хватает 9

4 Первый запуск и привязка телефона 11

5 Новый помощник без общего секрета 13

6 Разговор и действие с подтверждением 14

7 Календарь близкого человека 16

8 Незнакомец сначала просит контакт 17

9 Отозвать доступ и потерять телефон 18

10 Доверие простыми словами 19
- 10.1 Что видит сервер 19
- 10.2 Подписи не зависят от транспорта 19

11 Что собираем на хакатоне 21
- 11.1 Демо на шесть с половиной минут 21
- 11.2 Риски и запасные варианты 22

12 После хакатона: продукт и решения 23
- 12.1 Вопросы к владельцу 23

0 Один фундамент, разные продукты

Swarma — это платформа, на которой у человека работают постоянные агенты-помощники. Платформа отвечает на три вопроса:

- **где и как агент работает:** своя учётная запись на компьютере, свои инструменты, запуск и остановка;
- **кто он такой:** у агента свой ключ, и любое его сообщение можно проверить;
- **что ему можно:** права выдаёт только владелец, они узкие и отзываемые.

Поверх этого фундамента можно строить разные продукты. Мы видим два направления.

Для бизнеса — фабрики автоматизации. Команды агентов ведут разработку или другой процесс компании: бухгалтерию, поддержку, исследования. Люди работают с ними в командных пространствах с комнатами и обсуждениями, как в Slack. Для этого подходит Matrix — мы уже так работаем сами.

Для человека — мессенджер. Обычное приложение-переписка, как iMessage. В нём рядом с людьми живут постоянные помощники: календарь, документы, домашние дела. Можно написать близкому человеку, своему помощнику или помощнику близкого человека — например, спросить у календаря жены, свободна ли она в пятницу. Для этого подходит XMPP.

Общим у двух направлений должен быть не интерфейс, а доверие: проверяемая личность и узкие права. предложено

0.1 Как это рассказать

Подача	Чем сильна	Что надо оговорить
Платформа и два продукта	Сразу понятно, кому что продаём: бизнесу автоматизацию, человеку помощников. Модули общие	Два интерфейса — это не две разные системы доверия
Одна сеть доверия, много интерфейсов	Объясняет, как общаются семья, компания и агенты разных людей через разные серверы	Федерация не значит, что сеть уже есть или что писать можно кому угодно
Операционная система для агентов	Объясняет учётки, ключи, запуск и постоянные роли	Это метафора. Мы не заменяем iOS или macOS

Для хакатона предлагаем первую подачу. Начинаем с понятного вопроса: «Свободна ли она в пятницу?» Потом показываем, почему чужой помощник ответил ровно в пределах разрешения и ни словом больше. Платформа объясняет, почему поведению можно верить, но не заслоняет продукт. предложено

0.2 Что здесь план, а что уже есть

Часть нужных кирпичей платформа уже даёт: ключи агентов, регистрацию, запуск, формат подписанных сообщений. Мобильный клиент, адаптер XMPP, привязка телефона и сквозная сборка продукта ещё не готовы, и мы не делаем вид, что они готовы. Таблица в главе «Что собираем на хакатоне» прямо отделяет работающее от имитации.

Все адреса вида `example.test` в документе вымышлены. Форматы сообщений и правил определяют спецификации модулей. Этот документ их не расширяет, а только показывает, как ими пользоваться.

1 Matrix, XMPP или оба

Сначала главное: транспорт только доставляет сообщение. Права он не выдаёт. Разрешено ли действие, решает проверка подписи и гранта, и она одинакова для любого транспорта. Поэтому выбор между Matrix и XMPP — это выбор удобной формы общения, а не системы безопасности.

1.1 Где что удобнее

- **Matrix — командное пространство.** Комнаты, пространства (Spaces), обсуждения в тредах, много участников, история. Хорошо ложится на работу: проект, команда агентов, люди, которые заходят посмотреть и принять решение. Мы уже используем его для своих агентов.
- **XMPP — личная переписка.** Чаты один на один и небольшие группы, лёгкие клиенты на телефоне, адрес как у почты (`имя@сервер`), федерация между серверами разных провайдеров. Хорошо ложится на потребительский мессенджер.
- **Оба сразу.** Один и тот же агент может сидеть в командной комнате Matrix и отвечать человеку в XMPP. Подпись сообщения от транспорта не зависит, поэтому проверка одна и та же.
  предложено

1.2 Сравнение по существу

	Matrix	XMPP
Форма общения	Комнаты, Spaces, треды — готовая модель командного пространства	Личные чаты, список контактов, группы (MUC). Треды и навигацию по командам надо подбирать вместе с клиентом
Федерация	Серверы обмениваются событиями и состоянием комнат	Серверы разных доменов пересылают сообщения друг другу; нужны совместимые расширения
Сквозное шифрование	Olm/Megolm; устройства пользователя связаны через cross-signing	OMEMO; каждое устройство собеседника проверяется отдельно, единого «мастер-ключа» нет
Вход по ключу	Вход и шифрование — разные вещи. Наш вход агентов по JWT не равен подписи действия	Адрес (JID) — не ключ. Вход без пароля требует выбранного механизма SASL и привязки ключа к аккаунту
Сервер	Тяжелее: хранит состояние комнат и историю	Набор модулей задаёт вес. «XMPP легче» — правда только при одинаковых функциях
Push на телефон	Есть стандартный Push Gateway	Есть XEP-0357; связку с APNs и поведение iOS надо проверять
Клиенты	Element и другие	Много клиентов; совместимость OMEMO проверяется попарно

	Matrix	XMPP
Мосты	Application Service API для интеграций; мост, видящий открытый текст, меняет границу доверия	Component Protocol подключает сервис к серверу, но шифрование сам не сохраняет

Основания: Matrix Client-Server API, Server-Server API, каталог клиентов Matrix, каталог XMPP. Сравнение не проверяет конкретный сервер или библиотеку.

1.3 Одна личность, два пути доставки

У агента одна личность и один ключ. Модуль a2a умеет разные транспорты: для командной комнаты выбирает Matrix, для личного разговора — XMPP. Подписанное содержимое проходит одну и ту же проверку, и адаптер не меняет подписанные байты. Отличаются только оболочка, адреса и шифрование. Адаптер обязан сверить адресата и комнату с тем, что подписано. предложено



Рис. 1.1. Два транспорта сходятся у одной проверки полномочий

Это не значит, что все комнаты надо мостить друг в друга. Перенос разговора в другой транспорт не переносит право читать историю, а повторная доставка по второму пути не должна повторно выполнять действие. В MVP у каждого разговора один транспорт. Копирование между транспортами выключено, пока не проверены адресаты, защита от повторов и сохранность точных байтов. предложено

2 Какой XMPP нужен продукту

«Сервер поддерживает XMPP» — этого мало. XMPP — это ядро плюс десятки расширений (XEP), и каждый клиент поддерживает свой набор. Поэтому перед разработкой команда фиксирует конкретные версии сервера, библиотек и расширений и проверяет, что они работают вместе. Ниже — предлагаемый набор, а не наш собственный протокол. предложено

Что нужно	Расширение	Зачем в MVP и что проверить
Шифрование	XEP-0384 OMEMO 0.9.1 (статус Experimental)	Основа. Проверить новое устройство, доставку после офлайна и смену ключа без молчаливого доверия
Группы	XEP-0045 MUC	Маленькая закрытая группа. Проверить членство, удаление участника и список получателей шифрования
Каналы	XEP-0369 MIX	После MVP. Это не замена MUC один в один; совместимость с OMEMO проверить отдельно
Ключи устройств	XEP-0060 PubSub, XEP-0163 PEP	Публикация ключей OMEMO и списков устройств. Проверить чтение через федерацию и смену списка
История	XEP-0313 MAM 1.1.3	Архив зашифрованных сообщений. Новое устройство старые ключи из архива не получает
Несколько устройств	XEP-0280 Carbons 1.0.1	Копии на свои устройства. Проверить дубли и шифрование для каждого устройства
Уведомления	XEP-0357 Push 0.4.1 (статус Deferred)	Проверить сервер, push-сервис и iOS в фоне. Не готово — честно показываем демо только с открытым приложением; никакого текста в уведомлении
Файлы	XEP-0363 HTTP Upload 1.2.0	Вне основного демо. Upload сам файл не шифрует: шифруем на клиенте, ключ передаём внутри OMEMO
Стык с сервером	XEP-0114 Component Protocol 1.6	Кандидат для моста агентов. Права компонента не заменяют подписей агентов
Вход по ключу	XEP-0178 SASL EXTERNAL 1.2	Вход по клиентскому сертификату. Проверить связь адреса с ключом, выпуск, отзыв и поддержку на iOS и сервере

Для первой сборки мост агента может быть обычным XMPP-клиентом на станции, без серверного компонента. Если мы всё же используем компонент, он только пересылает сообщения, а расшифровка остаётся у агента на станции. Расшифровка на общем сервере — это уже другой продукт, и называть его надо по-другому. предложено

2.1 Чего не даёт вход без пароля

Passkey, подпись нашего конверта `swarm-envelope/2`, TLS-сертификат и ключ OMEMO — четыре разных механизма. Вход по SASL EXTERNAL не означает, что сервер понимает WebAuthn или ключи Keymaker. Расширения XEP-0388 и XEP-0440 задают рамки, но не дают готового входа «любым ключом Swarma».

Пока этот путь не проверен, аккаунты для демо заводим вручную, а сертификаты настраиваем отдельно. На экране так и написано: «Вход подготовлен для демо». Нельзя назвать пароль или JWT «входом по ключу» и считать задачу решённой. Какой вход будет в продукте — открытый вопрос. предложено

3 Из чего собирается мессенджер

Четыре части, у каждой своя роль:

- **Клиент** на телефоне или компьютере — окно разговоров и решений. Здесь же ключ устройства человека.
- **Станция** — компьютер, на котором работают агенты. У каждого агента своя учётная запись, свои инструменты и права.
- **Сервер XMPP** доставляет сообщения и хранит их в зашифрованном виде.
- **Keymaker** (служба ключей) хранит ключи агентов и подписывает от их имени. Кипер — главный агент владельца, он координирует помощников. Это разные роли, и их нельзя смешивать.

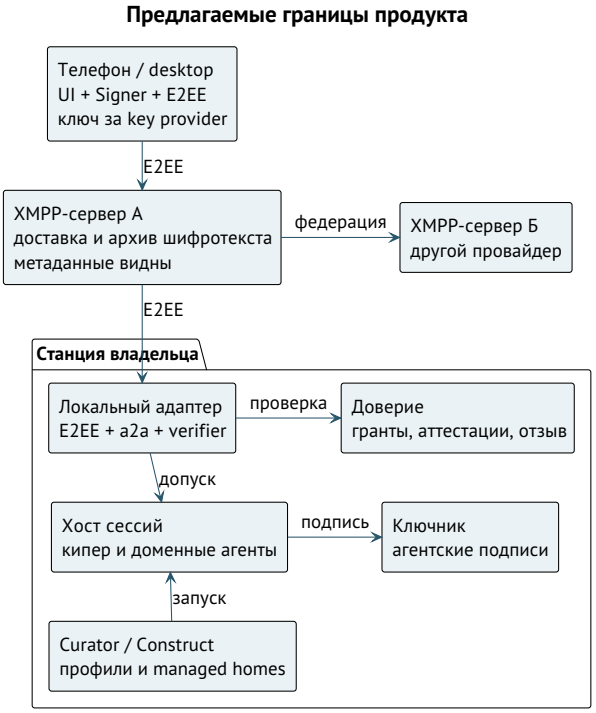


Рис. 3.1. Сервер стоит снаружи: он не расшифровывает и не исполняет

Шифрование работает от телефона до адаптера агента на станции. Агент читает текст, потому что должен ответить, и модель, на которой он работает, тоже его видит. Обещание «сервер видит только шифротекст» касается серверов доставки, а не самого агента и его модели. предложено

3.1 Что уже есть и чего не хватает

Состояние модулей на конец октября 2026 года. Даже если отдельный модуль проверен, это не значит, что готова сборка продукта из них.

Часть	Что даёт платформа	Чего не хватает; допущение для хакатона
Клиент iOS/desktop	В проекте Swarm Signer есть ядро правил и интерфейс к ключам; ключ устройства P-256 в Secure Enclave	Клиент XMPP и весь интерфейс ещё строить. Начинаем с iOS и простой панели на станции
Keymaker	Ключи агентов, отдельное назначение для подписи сообщений (`swarma-msg`), аттестации ключей; проверен на нескольких учётках	Подключить к новому мосту. В демо тестовые личности регистрируем заранее; ключи никогда не попадают в промпт
Регистратор	Вход агентов на сервер Matrix по JWT	Это не вход в XMPP. Для демо аккаунты заводим вручную
Брокер учётных данных	Единственный владелец логинов к моделям	Не путать с аккаунтом в мессенджере. Демо использует заранее подготовленный доступ к модели
Менеджер пользователей	Станции: своя учётка ОС для каждого агента	Создание помощника с телефона ещё не связано. В демо учётки подготовлены вручную
Curator, curator-run, Construct	Профили агентов, управляемые домашние каталоги, запуск	Нужные профили готовим заранее. Не обещаем кнопку «создать любого помощника»
Хост сессий	Мост в живую сессию агента: ввод и вывод	Проверить ввод, вывод и восстановление через XMPP; начинаем с одного агента
a2a	Абстракция транспорта; сейчас работает Matrix	Нужен провайдер XMPP и сверка адресатов; проверка подписей остаётся той же
Слой доверия	Спецификация подписанных сообщений: конверт `swarm-envelope/2`, гранты `grant/1`, команды оператора `operator-act/1`, аттестации `attestation/1`, отзывы `revocation/1`	Спецификация — ещё не работающая проверка. Если проверяющего ядра нет, действие блокируется или явно показывается как симуляция
Сервер XMPP	Стандартный федеративный протокол	Выбрать сервер и библиотеки. Сначала один свой закрытый сервер, два домена — следующий этап

Ядро Signer отделено от интерфейса, от хранения ключей шифрования и от аппаратной подписи. Исследование рекомендует для ядра Rust/UniFFI с Matrix Rust SDK, но язык ещё не утверждён, а библиотеку OMEMO оно не выбирало: для XMPP нужна своя проверка. На хакатоне можно сократить число платформ, но нельзя прикрыть отсутствие проверки красивым экраном Face ID. **предложено**

4 Первый запуск и привязка телефона

Задача не в том, чтобы войти на сервер. Задача — связать телефон со своим корнем доверия, то есть со своей станцией и её главным агентом. QR-код запускает привязку, а сверка эмодзи (SAS) ловит подмену канала. Ни QR, ни совпавшие эмодзи сами никаких прав не выдают. Точный протокол привязки, срок жизни приглашения и доказательство владения ключом ещё предстоит закрепить. **предложено**

1. На станции уже работают Keymaker и главный агент с аккаунтом `keeper@example.test`. Установщик показывает, какую станцию человек сейчас связывает с телефоном.
2. Телефон создаёт свой ключ устройства. На iPhone это P-256 в Secure Enclave: закрытый ключ никогда не покидает чип и не передаётся даже ядру приложения.
3. Владелец сканирует QR со своей станции. Телефон и станция показывают одинаковый набор эмодзи для этой попытки, и человек сверяет их глазами.
4. Эмодзи не совпали или человек отменил — попытка закрывается, ничего не удостоверено. Совпали — владелец отдельно удостоверяет ключ телефона и его назначение через церемонию корня.
5. Телефон запоминает доверенный корень. Для OMEMO каждый отпечаток устройства проверяется и удостоверяется отдельно: аналога cross-signing из Matrix здесь нет.
6. Приложение показывает главного агента и выданные ему права. Первый разговор начинается только после проверки цепочки и готовности шифрования.

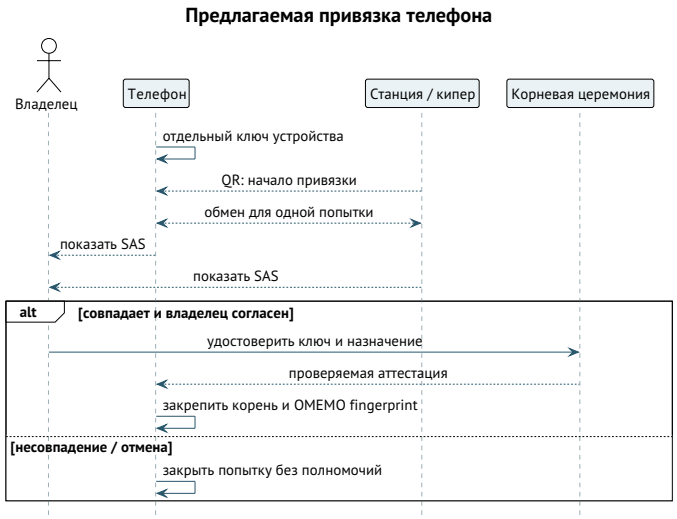


Рис. 4.1. QR начинает попытку; доверие появляется только после сверки и удостоверения

Первое сообщение — «Покажи моих помощников». Правильный исход: ответ своего кипера с проверенным происхождением. Отказ, который тоже должен работать: QR подменили или эмодзи разные. Тогда чат не становится привязанным, и никаких прав и ключей чужой стороне не добавляется.

Упрощение для хакатона. Один телефон и одна заранее подготовленная станция; подпись корнем делаем вручную. Если сверка эмодзи ещё не готова, сверяем полный отпечаток ключа вручную и так это и называем. Нельзя показывать слайд с эмодзи как работающую защиту, если она не работает. предложено

5 Новый помощник без общего секрета

Человек пишет: «Добавь помощника для календаря». Кипер организует создание, но сам не может раздавать себе право заводить какие угодно аккаунты. В итоге появляется отдельная личность `calendar@example.test` со своей учётной записью на станции и узким набором инструментов. предложено

1. Приложение показывает профиль нового помощника и права, которые он просит. Например: «читать только демонстрационный календарь». Любые права сверх этого владелец подтверждает отдельно.
2. Кипер передаёт одобренную заявку модулям, которые создают учётку и профиль. В демо учётка и профиль подготовлены заранее.
3. Keymaker регистрирует личность помощника, привязанную к его учётке и поколению, и выпускает ему отдельный ключ. Главный секрет и закрытые ключи никогда не попадают в промпт.
4. Регистратор, а в демо — ручной шаг, заводит адрес в XMPP. Адаптер помощника получает свои ключи шифрования. Адрес и ключ связывает проверяемая запись, а не совпадение имён.
5. Curator запускает агента с нужным профилем и домашним каталогом, хост сессий подключает его ввод и вывод к мосту.
6. Телефон получает цепочку доверия нового помощника по уже проверенному каналу и проверяет её. Чат с ним появляется только после этого. Сообщение «Я Календарь» от кого попало чата не создаёт.

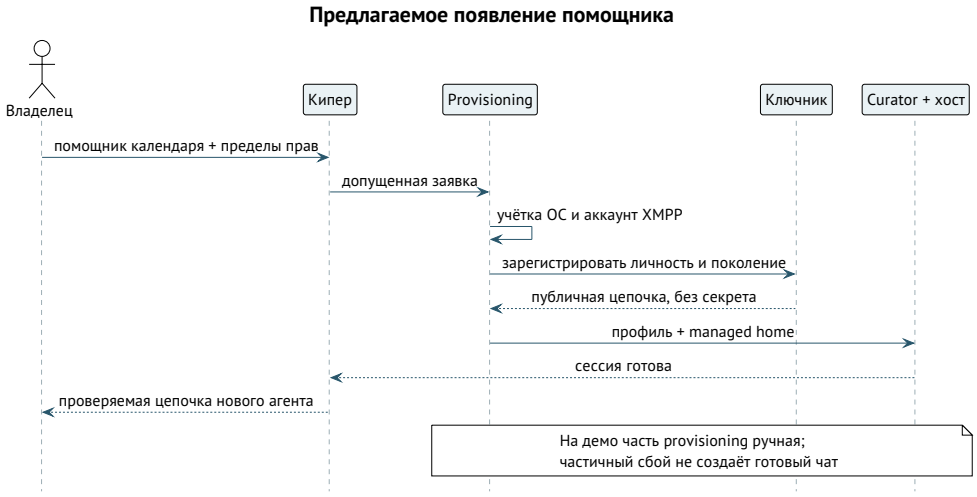


Рис. 5.1. Личность, аккаунт и сессия создаются отдельными шагами

Вывод ключей из общего корня упрощает Keymaker выпуск ключей, но не заменяет ни аттестацию, ни грант. И это не настройка OMEMO: для шифрования у помощника свои устройства и сессии. Формул и форматов здесь не вводим, их задают спецификации.

Проверка на отказ. Повторная заявка не создаёт второго помощника. Неодобренный профиль или чужая учётка ключа не получают. Если создание оборвалось на полпути, приложение показывает «не готов», а не рабочий чат. Порядок отката и защиту от повторов должен закрепить контракт; на хакатоне недоделанный экземпляр отключаем вручную. предложено

6 Разговор и действие с подтверждением

«Какие у меня встречи?» и «Удали встречу» в чате выглядят одинаково, но проходят разные правила. Обычный вопрос может привести только к разрешённому чтению. Изменение приходит отдельной карточкой с точным действием: что меняется, где и у кого. Модель сама не решает, какой уровень полномочий ей нужен. предложено

1. Человек пишет обычное сообщение. Оно зашифровано; мост на станции проверяет, от кого оно и разрешено ли этому собеседнику общаться с агентом.
2. Агент читает данные через узкий инструмент. Чтобы показать свободное время, не нужно подтверждать весь разговор через Face ID.
3. Если нужно изменить что-то важное, агент только предлагает действие. Приложение показывает человеку точный объект и изменение.
4. Человек подтверждает через Face ID. Ключ телефона подписывает заранее подготовленные байты действия. Отмена означает, что к исполнению ничего не уходит.
5. Проверка на станции смотрит всё: подпись, назначение ключа, цепочку доверия, грант, свежесть, отзыв, адресата и повторы. Перед самим действием исполнитель проверяет это ещё раз.
6. В чат приходит отдельный результат. «Доставлено» значит только доставку, а не «встреча удалена».

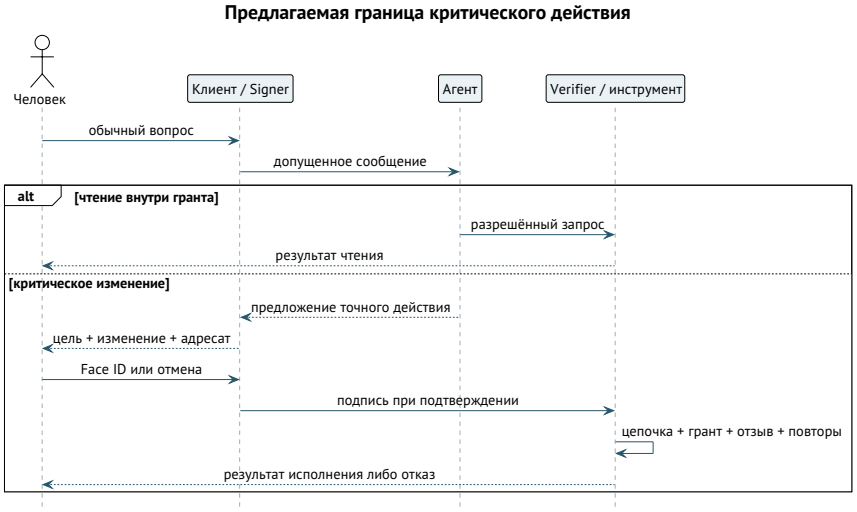


Рис. 6.1. Обычное чтение и важное изменение идут разными путями

Ключ телефона — P-256 из Secure Enclave, ключи агентов — Ed25519. Важная оговорка: обычная подпись P-256 не доказывает удалённой стороне, что человек именно приложил палец. Чтобы связать присутствие человека с конкретным действием, нужен отдельный контракт и тестовые векторы. **В версии v0 ни один способ подтверждения не квалифицирован как подтверждение присутствия (A3).** Поэтому действия, которые расширяют права или критичны, в v0 закрыты, а сужающие (например, отзыв) работают.

Проверка на отказ. Отменили Face ID, подменили цель после показа, повторили старое подтверждение, гранта нет — календарь не меняется. Рядом проверяем, что то же действие с правильными условиями проходит. На хакатоне используем тестовый календарь, а кнопка, имитирующая Face ID, прямо подписана «симуляция». предложено

7 Календарь близкого человека

У двух людей разные корни доверия. Семья — не общий аккаунт для их агентов. Человек А спрашивает помощника-календарь человека Б: «Есть ли у неё свободное время в пятницу?» В ответ можно получить свободные интервалы, но не названия встреч. предложено

1. Люди добавляют друг друга в контакты и сверяют ключи. Адрес `calendar-b@example.test` — только адрес; право задаёт проверенный ключ и цепочка доверия.
2. Человек Б открывает карточку разрешения: кому, к какому календарю, только свободные интервалы, до какого числа. Создавать события и передавать право дальше нельзя.
3. Подтверждённый грант публикуется в реестре владельца. У человека А появляется понятная строчка «может узнавать свободное время», а не «полный доступ к агенту».
4. Запрос подписывает человек А или его одобренный агент. Если спрашивает агент А, грант должен называть именно его или допускать такую передачу. Родство этого не заменяет.
5. На стороне Б программа, а не модель, проверяет область и срок разрешения. Узкий адаптер календаря возвращает только свободные интервалы.
6. Ответ подписывается, шифруется для разрешённых получателей и приходит в тот же разговор. Другие чаты ни истории, ни деталей календаря не получают.

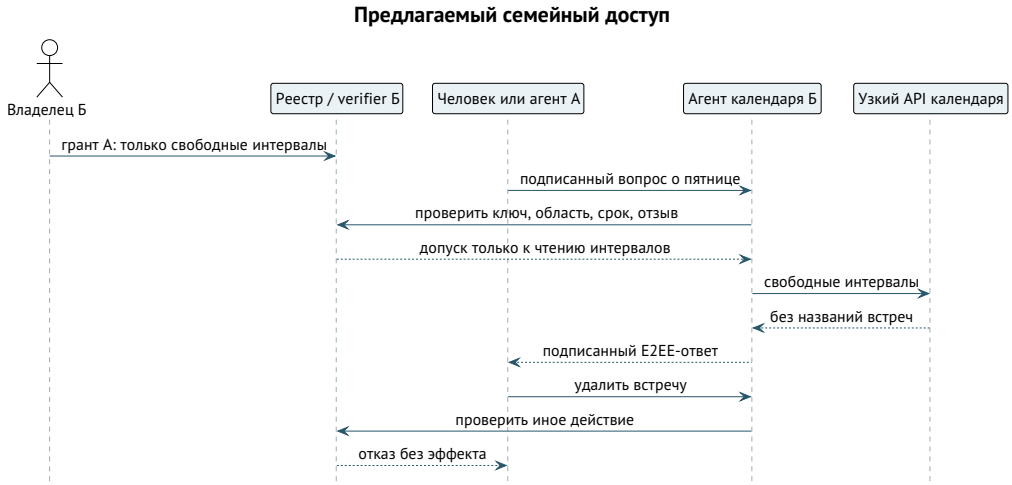


Рис. 7.1. Семейный грант разрешает спросить о занятости, но не менять календарь

Почему важен именно узкий адаптер: если модель сначала увидела весь календарь, обещание «названия встреч не раскрываются» уже держится только на её послушании. Поэтому в MVP нужен отдельный вызов «только свободные интервалы», а не просьба к модели скрыть лишнее. предложено

Проверка на отказ. Тот же человек просит название встречи или её удаление — отказ, без деталей и без изменений. Просроченный или отозванный грант тоже закрывает чтение. Рядом — проверка, что разрешённый вопрос о свободном времени проходит. Приглашение в семейную группу само по себе календарь не открывает.

8 Незнакомец сначала просит контакт

По умолчанию незнакомцам закрыто всё, и это проверяется до того, как сообщение попадёт к агенту. От неизвестного ключа агент не принимает ни поручений, ни файлов. Модели не предлагают «самой решить, можно ли ответить». Но продукту нужна возможность познакомиться. Для этого есть отдельный узкий канал — запрос контакта. Это не разговор с агентом. предложено

1. `visitor@example.test` отправляет запрос контакта: представляется и просит конкретный вид общения. Спросить что-то у календаря он пока не может.
2. Входной фильтр ограничивает частоту и размер запросов. Текст запроса не попадает в промпт и не запускает инструменты; приложение показывает его как непроверенные данные.
3. Владелец отклоняет запрос или сверяет ключ надёжным способом. Отображаемое имя, домен сервера и фраза «ваш партнёр разрешил» личность не подтверждают.
4. Если владелец согласен, он выдаёт отдельный узкий грант. Например: только спросить свободное время на ближайшую неделю. Разрешение общаться и доступ к данным показываются раздельно.
5. Следующий подписанный запрос проходит обычную проверку. Без гранта на конкретное действие агент не принимает его как поручение.

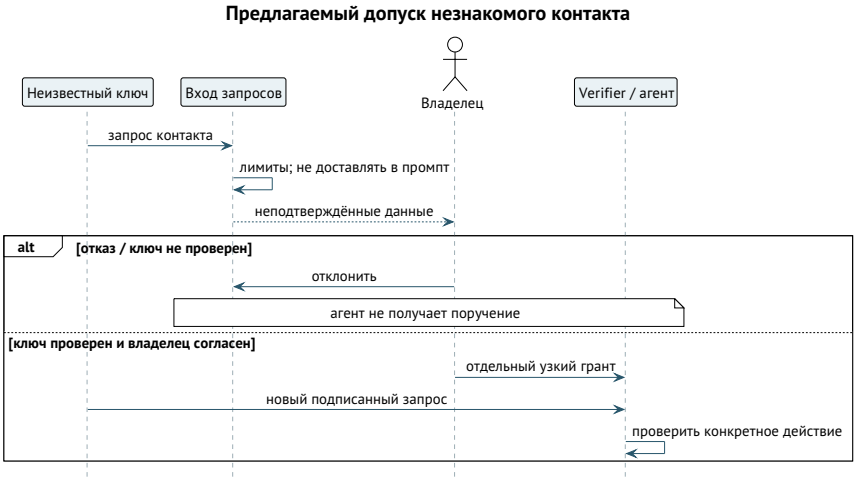


Рис. 8.1. Запрос контакта не попадает к агенту до решения владельца

Это предложение продуктовой границы, готового формата запроса ещё нет. На хакатоне отдельную очередь запросов можно заменить ручным добавлением отпечатка ключа. Нельзя одного: открыть агенту все входящие и назвать это белым списком. предложено

Проверка на отказ. Незнакомец повторяет запрос, подменяет имя на имя близкого человека или присылает чужую цитату разрешения. Агент не запускается, календарь не читается, очередь не растёт бесконечно. После явного узкого гранта разрешённый запрос проходит. Отключать белый список ради удачного демо нельзя.

9 Отозвать доступ и потерять телефон

Отзыв закрывает доступ на будущее. Уже прочитанное он не стирает и сохранённую у собеседника историю не забирает. Закрыть чат, выйти из аккаунта и отозвать ключ — три разные операции.

1. Обычный отзыв: владелец выбирает разрешение в списке, например «близкий человек может спрашивать свободное время». Подписанный отзыв публикуется в реестре.
2. Проверка обновляет своё состояние и перед следующим чтением или действием проверяет права заново. Если проверить отзыв не удалось, грант не считается действующим.
3. Телефон потерян: владелец берёт оставшееся доверенное устройство и корневой FIDO-ключ или заранее подготовленный резерв. Отзывает ключ потерянного телефона и доверие к его отпечатку OMEMO.
4. Отдельно закрываются сессии входа на сервер и обновляется список устройств шифрования. Отзыв ключа подписи и удаление устройства OMEMO — разные действия, их надо согласовать.
5. Новый телефон проходит новую привязку и аттестацию. Старые разрешения не восстанавливаются ни по имени аккаунта, ни по просьбе в чате.

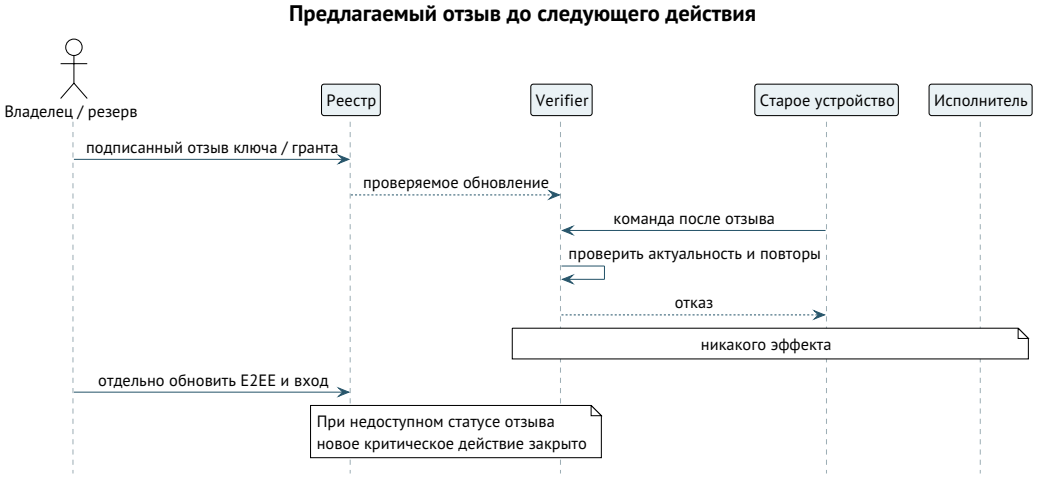


Рис. 9.1. Отзыв проверяется перед каждым новым действием, а не при доставке

Проверка на отказ. Старый телефон после отзыва присылает ранее подписанную команду — ничего не происходит. Рядом проверяем: разрешённое действие с оставшегося устройства при действующем гранте проходит. Если реестр недоступен, важные действия закрыты, а приложение честно пишет «проверка не завершена» вместо зелёной галочки.

Как быстро действует отзыв. В версии v0 отзыв срабатывает не позже чем через 60 секунд плюс возраст снимка реестра у проверяющего. «Мгновенно» мы не обещаем. Что именно считать моментом «отзыв завершён», решает владелец платформы — это открытый вопрос.

Если потеряны и телефон, и единственный корневой ключ, а резерва не было, восстановление пока не определено. Сброс пароля у провайдера не должен молча создавать новый доверенный корень. На хакатоне показываем заранее подготовленную процедуру, а не восстановление на все случаи. открыто

10 Доверие простыми словами

Приложение отвечает человеку на три разных вопроса: «Кто это?», «Что ему можно?» и «Что я сейчас подтверждаю?» Им соответствуют три механизма:

- **аттестация** удостоверяет ключ и его назначение;
- **грант** ограничивает, что можно сделать;
- **отзыв** прекращает доступ.

Подпись доказывает, кто отправил байты, но не то, что ответ правдив.

Уровень уверенности	Как это выглядит в приложении	Чего этот уровень не даёт
A0: отправителя назвал сервер	«Личность не проверена»; только запрос контакта	Прав и подтверждения важных действий
A1: проверенное устройство или ключ агента	«Ключ проверен»; общение в рамках выданных прав	Права менять календарь; доказательства решения человека
A2: человек подписал точное действие	Конкретное действие внутри гранта	Подтверждения присутствия, если оно требуется
A3: телефон показал действие, человек подтвердил ключом	«Разрешить чтение свободного времени до 31 октября» с Face ID	Расширения гранта и других действий

В v0 уровень A3 никем не достигается. Ни один способ подтверждения пока не прошёл квалификацию. Поэтому в интерфейсе и на демо экран с Face ID для критичного действия либо помечен как симуляция, либо действие закрыто.

В Matrix устройства человека связаны через cross-signing и мастер-ключ. В XMPP нужна проверка отпечатка каждого устройства OMEMO и его аттестация. Ни TLS, ни анимация Face ID сами доступа не дают: для важных действий нужен контракт проверяемого присутствия.

10.1 Что видит сервер

При правильном шифровании и проверенных устройствах сервер хранит только шифротекст содержимого. Но он видит адреса, кто с кем общается, время, размеры и служебное состояние. Он может задержать сообщение или подсунуть неполный список устройств, и клиент не должен принимать это за новую доверенную личность. Федерация этих ограничений не снимает.

Агент читает текст, захваченное устройство может его раскрыть. Вложения шифруются отдельно. Push без текста всё равно выдаёт сам факт сообщения. «Только шифротекст» относится к содержимому, а не ко всей информации об общении.

10.2 Подписи не зависят от транспорта

Каждый тип подписанной записи (конверт, грант, аттестация, отзыв) имеет свою доменную метку из закрытого списка, поэтому подпись одного типа нельзя выдать за другой. Устройства человека подписывают P-256, агенты — Ed25519; алгоритм и назначение ключа проверяются точно.

Сообщение агента привязано к его поколению. У агента постоянный ключ, но права выдаются на конкретное поколение его учётки. Поэтому в подписанные байты сообщения входит ссылка на аттестацию автора, то есть на его поколение и регистрацию. Проверяющий требует, чтобы

ссылка совпала с предъявленной действующей аттестацией. Сообщение, подписанное от имени прошлого поколения, отклоняется, даже если ключ тот же. Иначе старое сообщение можно было бы выдать за новое. Этот случай нашло коллективное исследование, и в спецификации S0 его сейчас исправляют.

Секреты лежат в разных местах. Логины к моделям — у брокера. Ключи шифрования — в хранилище клиента. Ключи агентов — у Keymaker. Ключ человека — в Secure Enclave телефона.

11 Что собираем на хакатоне

Цель — показать один полезный путь от начала до конца и то, как система отказывает там, где должна. Доделывать всю платформу не нужно, но каждая имитация видна зрителю. Шифрование берём из проверенной библиотеки, свой OMEMO не пишем. предложено

Строим по-настоящему	Имитируем, готовим вручную или откладываем
Простой iOS-клиент: список чатов, разговор, карточка разрешения, понятные ошибки	Полноценный клиент для компьютера; пока панель на станции
Шифрованная переписка двух людей и разговор с агентом на одной выбранной связке OMEMO	Свой бренд сервера и выбор провайдеров; аккаунты заведены вручную
Один адаптер XMPP к одному агенту через хост сессий	Автоматическое развёртывание станции и создание любых агентов
Проверка узкого разрешения перед чтением только свободного времени из тестового календаря	Настоящие личные календари, платежи, удаление реальных данных
Разрешённый запрос, отказ на лишнее, отзыв и повтор запроса после отзыва	Если общей проверки ещё нет — явная симуляция без доступа к настоящим инструментам
Аттестация тестовых ключей корнем и проверка цепочки, если модуль готов	Церемония корня вручную; восстановления после полной потери корня нет
Face ID для критичных действий — **только как помеченная симуляция**: в v0 A3 не квалифицирован	Настоящий критичный эффект закрыт
Журнал решений проверки без чувствительного текста	Push, файлы, MIX, поиск людей, несколько моделей — после основного пути

11.1 Демо на шесть с половиной минут

Это план сценария, а не замер скорости продукта.

1. **0:00–0:45.** Два человека переписываются. Показываем шифрование и что сервер видит только метаданные.
2. **0:45–1:45.** Привязываем телефон к станции: QR и эмодзи или честная ручная сверка отпечатка.
3. **1:45–2:30.** Просим помощника-календарь. Показываем отдельную личность и заранее подготовленный профиль; прямо говорим, что создан вручную.
4. **2:30–4:00.** Выдаём узкое семейное разрешение. Спрашиваем про пятницу и получаем только свободные интервалы.
5. **4:00–5:00.** Просим название встречи или удалить её — отказ. Показываем, что приглашение в чат доступа не дало.
6. **5:00–6:00.** Отзываем разрешение и повторяем тот же запрос — отказ. Затем владелец задаёт свой разрешённый вопрос — проходит.
7. **6:00–6:30.** Показываем, что было имитацией (включая Face ID), и следующий шаг: второй сервер или push.

11.2 Риски и запасные варианты

Риск	Что проверить заранее	Допустимое упрощение
Клиенты OMEMO несовместимы	Два клиента, офлайн, новое устройство, подменённый отпечаток	Одна проверенная пара клиентов; открытый текст не выдаём за шифрование
Вход по ключу не готов	Настоящий вход и отзыв на выбранном сервере	Ручной вход с явной пометкой
Нет общего ядра проверки	Разрешённый запрос и отказы при подмене цели и после отзыва	Только симуляция на тестовом календаре
iOS не получает push	Заблокированный экран, возврат из фона	Демо с открытым приложением и объяснением
Федерация не работает	Два домена, сверка ключей, отказ при подмене	Один сервер; не называем это проверенной федерацией
Мост к сессии теряет сообщения	Обрыв и повтор доставки, отдельная квитанция исполнения	Один заранее запущенный агент; доставку не выдаём за исполнение

12 После хакатона: продукт и решения

Хакатон проверяет две вещи: понимает ли человек узкое разрешение и получает ли он полезный ответ. Настоящему продукту нужна надёжность и повторяемые гарантии на реальных устройствах, а не больше экранов. Ниже — порядок работ, который мы предлагаем вернуть в дорожную карту платформы. предложено

Следующий результат	Что получает платформа
Ядро Signer и работа с ключами устройства	Общие тестовые векторы подписанных сообщений, проверка отмены и точных байтов, утверждённый язык ядра
Провайдер XMPP в a2a	Контракт адресов, адресатов, повторов и квитанций; проверка на двух доменах и при смене устройств OMEMO
Автоматическое создание помощников	Учётка, ключ, аккаунт, профиль и сессия создаются одной операцией с откатом при сбое
Потеря устройства без потери контроля	Резерв корня, отзыв входа и шифрования, свежесть и защита реестра от отката, работа офлайн
Нормальный мобильный цикл	Push без текста, работа в фоне, переподключение, перенос ключей шифрования, история без потери границ
Безопасные инструменты между владельцами	Узкие API данных вместо доступа модели ко всему; тесты границ и аудит без лишнего содержимого
Агенты на разных станциях	Контракты сессий и запуска, явное владение и остановка; логины к моделям остаются только у брокера

Готовность подтверждают сквозные испытания: разрешённый семейный запрос проходит, а расширение прав, повтор, отмена и отзыв ничего не меняют. Для каждого нового правила допуска нужен тест, который убирает именно это правило и показывает, что запрещённое тогда проходит. Две реализации, которые одинаково ошибаются, — не доказательство правильности.

12.1 Вопросы к владельцу

1. Какую подачу и название берём? Кто первый пользователь: один человек, семья или команда?
2. Хватит ли на старте iOS и панели на компьютере? Когда нужны Android и полноценный клиент для компьютера?
3. Какой сервер XMPP и какие библиотеки проверяем? Нужен ли второй домен уже в демо? Кто обслуживает сервер?
4. Что именно удостоверяет привязка по QR и эмодзи, как удостоверяется корень и где лежит его резерв? Что считаем подтверждением присутствия на компьютере?
5. Какие окна свежести, хранения повторов и распространения отзыва принимаем? Что показывает приложение, если проверить не удалось?
6. Кто может прислать запрос контакта, как ограничиваем спам и когда открываем поиск людей?